

ACTIVIDAD LABORATORIO NO.2
EL USUARIO COMO PIEZA FUNDAMENTAL DEL DESPLIEGUE DE CONTROLES INTERNOS
Análisis del factor humano en los sistemas de gestión de seguridad de la información y de su verificación en el proceso auditor

PRESENTADO POR:
ALEJANDRO DE MENDOZA

PRESENTADO AL PROFESOR:
ING y DR WILSON CASTAÑO GALVIS

FUNDACIÓN UNIVERSITARIA INTERNACIONAL DE LA RIOJA
BOGOTÁ D.C.
23 DE AGOSTO
2026

TABLA DE CONTENIDO

1.	Introducción.....	3
2.	Marco De Referencia: El Usuario Dentro Del Sistema De Control Interno.....	3
3.	¿Puede Un SGSI Cumplir Expectativas Imponiendo Solo Un Marco Tecnológico Y Normativo? ...	4
3.1	El argumento normativo: la concienciación como requisito exigible.....	4
3.2	El argumento estructural: las personas como capa del sistema	4
3.3	El argumento empírico: la evidencia del Kit de Concienciación.....	5
3.4	Matización: qué sí resuelve el marco tecnológico y normativo	5
4.	Consecuencias de la falta de comprensión de las medidas de seguridad	5
4.1	Consecuencias operativas	6
4.2	Consecuencias de cumplimiento y hallazgos de auditoría.....	6
4.3	Consecuencias económicas, legales y reputacionales	6
4.4	Consecuencias sistémicas sobre el propio SGSI	7
5.	El auditor frente a la brecha entre política declarada y uso real	7
5.1	¿Por qué debe evaluarla?	7
5.2	¿Cómo evaluarla? Técnicas, evidencias e indicadores	7
5.3	Límites, precauciones metodológicas y consideraciones legales.....	9
6.	Propuesta de aplicación: el Kit de Concienciación como control auditable.....	9
8.	Conclusiones	10
9.	Bibliografía	11
10.	AGRADECIMIENTO	11

1. Introducción

La seguridad de la información suele presentarse como un problema tecnológico, cuando en la práctica se comporta como un problema sociotécnico. Una organización puede desplegar cortafuegos, sistemas de detección de intrusos, cifrado y una política documental impecable, y aun así ver comprometidos sus activos porque una persona ejecutó un archivo adjunto, reutilizó una contraseña o entregó un código de verificación por teléfono. Este documento examina esa tensión a partir de la pregunta que estructura la Actividad 2: hasta qué punto el usuario constituye una pieza fundamental del despliegue de controles internos y no un elemento accesorio del sistema.

El análisis se organiza en torno a las tres preguntas planteadas en el enunciado. La primera indaga si un sistema de gestión de seguridad de la información (SGSI) puede cumplir sus expectativas limitándose a imponer un marco tecnológico y normativo. La segunda examina las consecuencias de que los usuarios no comprendan las medidas de seguridad que deben aplicar. La tercera traslada el problema al terreno de la auditoría: si el auditor debe evaluar la proximidad entre las dinámicas reales de uso de la tecnología y las políticas formalmente establecidas, por qué debería hacerlo y mediante qué métodos.

Para responderlas se articulan tres fuentes. En primer lugar, el Kit de Concienciación publicado por el Instituto Nacional de Ciberseguridad de España, material base indicado en el enunciado, del que se analizan tanto su diagnóstico de partida como su arquitectura instrumental (INCIBE, s. f.; INCIBE y METARED, s. f.). En segundo lugar, los contenidos desarrollados en las sesiones de la asignatura durante agosto de 2026, que aportan el marco conceptual sobre controles internos, tipología de auditorías y clasificación de hallazgos. En tercer lugar, la normativa técnica de referencia, principalmente ISO/IEC 27001:2022 e ISO 19011:2018, que permite contrastar las afirmaciones con requisitos verificables y no solo con apreciaciones de sentido común.

Conviene una advertencia metodológica previa. Varias de las cifras que circulan sobre el peso del error humano en los incidentes de seguridad proceden de informes sectoriales cuya metodología no siempre es reproducible ni comparable entre sí. En este documento se emplean como órdenes de magnitud que ilustran una tendencia, no como mediciones precisas, y así se señalan explícitamente en cada caso.

2. Marco De Referencia: El Usuario Dentro Del Sistema De Control Interno

Un control es, en términos operativos, la forma en que una organización protege sus activos frente a un riesgo determinado. Su lógica es sencilla: identificado un riesgo (por ejemplo, la interrupción del fluido eléctrico), se implanta un mecanismo que lo elimine o lo reduzca (un sistema de alimentación ininterrumpida). Lo relevante es que el control no elimina el riesgo por completo: lo reduce desde un nivel inherente hasta un nivel residual que la organización acepta formalmente (W. Castaño Galvis, comunicación personal, agosto de 2026).

Los controles admiten dos clasificaciones complementarias. Según su naturaleza se distinguen controles administrativos, de personas, lógicos y físicos, agrupación que guarda correspondencia con los cuatro temas en que ISO/IEC 27001:2022 reorganizó su Anexo A (organizativos, personas, físicos y tecnológicos). Según el momento en que actúan frente a la amenaza, se distinguen controles de prevención, de detección y de corrección, que operan de forma encadenada: si la prevención falla, debe actuar la detección; si la detección tampoco advierte el evento, entra la corrección.

El punto que interesa subrayar es que el usuario no aparece en una sola de estas categorías, sino que atraviesa todas. La formación del personal es un control administrativo y, a la vez, un control de prevención. La gestión del ciclo de vida laboral (qué ocurre antes, durante y después de la relación contractual) es un control de personas. La aplicación efectiva de una política de contraseñas robustas es lo que hace operativo un control lógico. Y el cumplimiento de los procedimientos de acceso al centro de datos es lo que sostiene un control físico. En las sesiones de clase esta transversalidad se sintetizó mediante la expresión «capa ocho» del modelo OSI: la persona situada entre la silla y el computador, a la que se atribuyó de forma aproximada el 70 % de los errores registrados en las organizaciones (W. Castaño Galvis, comunicación personal, agosto de 2026).

Esta distinción tiene una consecuencia conceptual que conviene precisar, porque suele confundirse. En el marco trabajado en clase, las amenazas son de origen externo y las vulnerabilidades son internas. Un empleado que desconoce cómo identificar un correo fraudulento no constituye, en rigor, una amenaza: constituye una

vulnerabilidad, es decir, una debilidad interna que una amenaza externa puede explotar mediante un vector de ataque concreto, entendido como el método o la ruta que emplea el atacante. Formular el problema en estos términos no es un matiz semántico: implica que la falta de concienciación es una debilidad imputable a la organización que no capacitó, y no un defecto atribuible a la persona que no supo.

3. ¿Puede Un SGSI Cumplir Expectativas Imponiendo Solo Un Marco Tecnológico Y Normativo?

La respuesta corta es que no, y conviene sostenerla en tres planos distintos, porque cada uno resiste un tipo diferente de objeción.

3.1 El argumento normativo: la concienciación como requisito exigible

El argumento más fuerte no es de conveniencia sino de conformidad. ISO/IEC 27001:2022 no deja la concienciación al criterio de la organización: la exige. La cláusula 7.3, «Toma de conciencia», ubicada en el capítulo de Apoyo, establece que las personas que realizan trabajo bajo el control de la organización deben ser conscientes de la política de seguridad de la información, de su contribución a la eficacia del SGSI (incluidos los beneficios de una mejora del desempeño) y de las implicaciones de no cumplir los requisitos del sistema. Este requisito alcanza no solo a los empleados, sino también a contratistas y terceros comprendidos en el alcance.

A ese requisito del cuerpo normativo se suma el control A.6.3 del Anexo A, «Concienciación, educación y formación en seguridad de la información», integrado en el tema de personas, que exige formación adecuada y actualizada según la función de cada persona y los riesgos reales de su puesto, y no un temario genérico uniforme.

La implicación es contundente: una organización que se limitara a desplegar tecnología y a publicar políticas no estaría solamente adoptando una estrategia poco eficaz, sino que estaría incumpliendo un requisito explícito de la norma que dice implementar. En una auditoría de certificación, esa ausencia sería objeto de hallazgo. Dicho de otro modo, el marco tecnológico y normativo por sí solo no puede satisfacer las expectativas del SGSI porque el propio SGSI, tal como lo define la norma, incorpora la concienciación entre sus componentes obligatorios.

3.2 El argumento estructural: las personas como capa del sistema

En las sesiones de la asignatura la implantación de un SGSI se describió apoyada en cinco elementos encadenados: liderazgo, políticas y procesos, tecnologías, controles y personas, cerrados por un monitoreo continuo (W. Castaño Galvis, comunicación personal, agosto de 2026). La secuencia no es decorativa: cada elemento habilita al siguiente y ninguno funciona aislado. La tabla 1 sintetiza esta arquitectura y muestra qué ocurre cuando cada capa se omite.

Tabla 1

Elementos de implantación de un SGSI y efecto de su omisión

Elemento	Función en el sistema	Efecto probable de su omisión
Liderazgo	Compromiso de la dirección y asignación de recursos.	Sin presupuesto ni respaldo, el proyecto no avanza; en clase se planteó como condición previa para siquiera iniciar la implantación.
Políticas y procesos	Definición de lo que debe hacerse y de cómo hacerlo.	La organización actúa por costumbre; no hay criterio contra el cual auditar.
Tecnologías	Medios técnicos de protección de los activos.	Las políticas quedan sin medios de aplicación y son inexigibles en la práctica.
Controles	Mecanismos concretos que reducen el riesgo inherente.	El riesgo permanece en su nivel inicial; no hay riesgo residual gestionado.
Personas	Ejecución cotidiana de los controles; «capa ocho».	Los controles existen documentalmente pero no se aplican; la cadena se rompe por el eslabón más débil.

Elemento	Función en el sistema	Efecto probable de su omisión
Monitoreo continuo	Medición, reporte y ajuste permanentes.	No se detecta la degradación del sistema ni se alimenta la mejora continua.

Nota. Elaboración propia a partir de los contenidos desarrollados en las sesiones de la asignatura (W. Castaño Galvis, comunicación personal, agosto de 2026) y de la estructura de ISO/IEC 27001:2022.

Junto a esta arquitectura se expusieron cuatro «reglas de oro» aplicables a cualquier SGSI: el compromiso de la dirección, el enfoque basado en riesgos, la mejora continua articulada mediante el ciclo PHVA (planear, hacer, verificar, actuar) y la concienciación del personal. Es significativo que la concienciación figure entre los principios rectores y no entre las actividades accesorias.

3.3 El argumento empírico: la evidencia del Kit de Concienciación

El Kit de Concienciación de INCIBE parte precisamente de esta constatación. Su diagnóstico sostiene que la mayor parte de las situaciones que afectan a la continuidad del negocio se relaciona, de una u otra forma, con la falta de preparación en ciberseguridad de quienes deben manejar la tecnología, y su propuesta se resume en reforzar la seguridad desde el núcleo de la empresa: las personas (INCIBE, s. f.).

El diseño del kit resulta revelador de esta lógica. No comienza con formación, sino con una medición: un ataque dirigido de tipo phishing desplegado mediante la herramienta Gophish, descrito explícitamente como evaluación inicial del nivel de concienciación, al que siguen ataques con ficheros maliciosos distribuidos por memorias USB y por enlaces en correo electrónico. Solo después se despliega el proceso formativo, y al final se repite la tanda de ataques como evaluación final (INCIBE y METARED, s. f.). Esta estructura de medición previa, intervención y medición posterior es, en términos metodológicos, un diseño pretest-posttest: reconoce implícitamente que la concienciación es una variable que se mide, no un estado que se declara.

3.4 Matización: qué sí resuelve el marco tecnológico y normativo

Sostener que el marco tecnológico y normativo es insuficiente no equivale a sostener que sea prescindible, y conviene evitar el desplazamiento contrario. Sin políticas formalmente aprobadas no existe criterio de auditoría: no se puede evaluar la conducta de un usuario frente a una norma que nadie escribió. Sin controles técnicos, la concienciación queda como única línea de defensa, lo que resultaría igualmente frágil, pues ninguna formación evita la totalidad de los errores. La formulación defendible es que el marco tecnológico y normativo constituye una condición necesaria pero no suficiente, y que su eficacia depende del grado de apropiación que los usuarios hagan de él. La formación es, en rigor, el mecanismo mediante el cual las políticas dejan de ser documentos y se convierten en conducta observable.

4. Consecuencias de la falta de comprensión de las medidas de seguridad

Las consecuencias de que los usuarios no comprendan las medidas de seguridad no se limitan al incidente técnico. Pueden ordenarse en cuatro niveles de creciente alcance organizacional, sintetizados en la tabla 2 y desarrollados a continuación.

Tabla 2

Tipología de consecuencias derivadas de la falta de comprensión de las medidas de seguridad

Nivel	Manifestación	Ejemplo ilustrativo
Operativo	Materialización de incidentes por ejecución de acciones aparentemente triviales.	Ejecución de un adjunto malicioso o clic en un enlace fraudulento; entrega de un código de verificación en un fraude de phishing.
Cumplimiento	Hallazgos de auditoría por controles declarados, pero no aplicados con rigor.	Capacitación en protección de datos declarada que se resuelve en dos horas: no conformidad menor.

Nivel	Manifestación	Ejemplo ilustrativo
Económico y legal	Costos de remediación, interrupción de la operación y sanciones administrativas.	Filtración de una base de datos personales con la consiguiente actuación de la autoridad de protección de datos.
Sistémico	Degradación de la capacidad del propio SGSI para mejorar.	Registros inexistentes o incompletos que impiden medir la eficacia del control y alimentar el ciclo PHVA.

Nota. Elaboración propia a partir de los casos y clasificaciones discutidos en las sesiones de la asignatura y del diagnóstico de INCIBE (s. f.).

4.1 Consecuencias operativas

El nivel más visible es la materialización del incidente. El correo electrónico concentra buena parte de este riesgo, y no por una debilidad técnica del protocolo sino por su alto componente humano: es el canal donde el atacante puede construir un contexto verosímil. Resulta ilustrativo el caso de ingeniería social relatado en clase, en el que se suplantó la identidad de una persona conocida para solicitar una transferencia urgente de dinero. Lo que permitió detectar el fraude no fue un control técnico, sino una anomalía en el registro del lenguaje: la supuesta remitente empleaba un tratamiento distinto del habitual (W. Castaño Galvis, comunicación personal, agosto de 2026). El episodio muestra que, ante vectores de ingeniería social bien contruidos, la capacidad de discriminación del usuario opera como control efectivo, y esa capacidad se forma o no se forma.

En cuanto a la magnitud del fenómeno, en clase se citaron cifras del orden del 70 % al 95 % de incidentes asociados a error humano, junto con estimaciones de costo promedio por incidente y de tiempo medio de detección superior a los doscientos días. Al proceder de informes sectoriales referenciados de forma oral, estas cifras deben tomarse como indicativas de una tendencia y no como mediciones exactas; su valor argumentativo reside en la coincidencia de distintas fuentes en situar el factor humano como componente mayoritario, no en el dígito concreto.

4.2 Consecuencias de cumplimiento y hallazgos de auditoría

Un segundo nivel, menos evidente, pero de impacto directo sobre la certificación, es el de los hallazgos de auditoría. Aquí la falta de comprensión no se manifiesta como incidente sino como incumplimiento documentado. En clase se ilustró con un ejemplo preciso: una organización declara contar con capacitación en protección de datos, pero la actividad se resuelve en dos horas. El control existe formalmente, pero no cumple con el rigor que su propia declaración supone, lo que configura una no conformidad menor. En el extremo opuesto, la ausencia total de un servicio declarado (por ejemplo, un sistema de protección del correo electrónico que en realidad no filtra nada) constituye una no conformidad mayor, con exigencia de acción inmediata.

Se añade un problema probatorio de primer orden. Si la organización afirma haber formado a su personal, pero no conserva registros, listas de asistencia ni resultados de evaluación, el auditor no puede dar el control por cumplido. En términos de ISO 19011:2018, la evidencia de auditoría debe ser verificable; una declaración sin soporte documental no satisface ese criterio. En la práctica, una actividad formativa realizada pero no registrada equivale, a efectos de auditoría, a una actividad no realizada.

4.3 Consecuencias económicas, legales y reputacionales

El tercer nivel comprende los costos derivados. Junto a los gastos directos de remediación y a la interrupción de la operación, aparece la dimensión regulatoria. En el contexto colombiano, el tratamiento de datos personales se rige por la Ley 1581 de 2012 y su supervisión corresponde a la Superintendencia de Industria y Comercio, que ha impuesto sanciones a organizaciones por incumplimientos en esta materia. Un ejemplo mencionado en clase resulta pertinente: la instalación de un circuito cerrado de televisión obliga a contar con una política de tratamiento de datos personales y con la señalización informativa correspondiente, obligación que no depende del área técnica sino del conocimiento que la organización tenga de sus deberes legales.

A ello se suma el efecto sobre la confianza de terceros. La certificación en ISO/IEC 27001 opera como señal de credibilidad ante clientes y socios comerciales; su pérdida o su no obtención por hallazgos vinculados al factor humano tiene un costo comercial que excede el incidente concreto.

4.4 Consecuencias sistémicas sobre el propio SGSI

El cuarto nivel es el más silencioso y probablemente el más grave a largo plazo. Un SGSI mejora porque mide; y mide a partir de registros que las personas generan al ejecutar los procedimientos. Cuando los usuarios no comprenden las medidas, tienden a no reportar incidentes menores, a no documentar excepciones y a no dejar traza de sus acciones. El resultado es que la organización pierde la materia prima de su propia mejora continua: el ciclo PHVA se detiene en la fase de verificación por ausencia de datos fiables. Se produce entonces una paradoja incómoda: cuanto menor es la concienciación, menos visible se vuelve el problema en los indicadores, y una organización puede exhibir métricas aparentemente favorables precisamente porque nadie está reportando.

5. El auditor frente a la brecha entre política declarada y uso real

5.1 ¿Por qué debe evaluarla?

El auditor de seguridad debe evaluar la proximidad entre las dinámicas reales de uso de la tecnología y las políticas establecidas. La justificación descansa en la naturaleza misma de la auditoría. Según se trabajó en clase, los controles internos constituyen una operación permanente, mientras que la auditoría es una evaluación periódica e independiente cuyo propósito es determinar si esos controles cumplen efectivamente su función (W. Castaño Galvis, comunicación personal, agosto de 2026). La auditoría se definió, además, como una revisión sistemática (paso a paso) y sistémica (atenta a los componentes y a sus interacciones).

Si el auditor se limitara a verificar la existencia documental de las políticas, estaría auditando el archivo y no el sistema. La finalidad declarada del proceso auditor es identificar brechas, entendidas como la distancia entre lo que la organización declaró implementar y lo que efectivamente cumple. Esa brecha, por definición, solo puede detectarse contrastando dos fuentes distintas: el documento y la conducta. Un auditor que consulte una única fuente no puede, estructuralmente, encontrar discrepancias entre ambas.

Existe además un fundamento normativo. ISO 19011:2018 establece que las fuentes de información de una auditoría pueden incluir entrevistas con empleados, observación de actividades y del ambiente de trabajo, información documentada, registros, resúmenes de datos e indicadores de desempeño, y retroalimentación procedente de encuestas y mediciones. La norma no restringe la evidencia al documento: incorpora expresamente la observación de la actividad real. Por su parte, la cláusula 7.3 de ISO/IEC 27001:2022 exige que las personas sean conscientes de la política, formulación que remite a un estado cognitivo del usuario y no a la mera existencia del texto. Verificar el cumplimiento de ese requisito obliga necesariamente a indagar en el usuario.

5.2 ¿Cómo evaluarla? Técnicas, evidencias e indicadores

El «cómo» admite una respuesta estructurada. En clase se distinguieron cuatro tipos de análisis según su naturaleza: cualitativo, cuantitativo, técnico y documental. Los dos primeros resultan especialmente pertinentes para evaluar el factor humano, y conviene combinarlos porque compensan sus limitaciones respectivas. La tabla 3 organiza las técnicas aplicables, la evidencia que produce cada una y su principal limitación.

Tabla 3
Técnicas de evaluación de la brecha entre política declarada y uso real

Técnica	Enfoque	Evidencia que produce	Limitación principal
Entrevista personal clave	Cualitativo	Grado de conocimiento declarado de la política y de las responsabilidades propias.	El entrevistado puede responder lo que considera esperable; mide declaración, no conducta.

Técnica	Enfoque	Evidencia que produce	Limitación principal
Observación directa del puesto	Cualitativo	Prácticas efectivas: bloqueo de sesión, escritorio despejado, credenciales visibles.	Efecto de reactividad: la conducta observada puede alterarse por la presencia del auditor.
Revisión documental y de registros	Documental	Asistencia a formación, resultados de tests, actas, reportes de incidentes.	Acredita la actividad, no su asimilación; un registro no prueba comprensión.
Simulacro de ataque dirigido	Cuantitativo	Tasa de apertura, de clic y de entrega de credenciales ante un estímulo controlado.	Requiere autorización previa y encuadre ético; mal ejecutado deteriora la confianza.
Evaluación de madurez	Cualitativo	Nivel de institucionalización del programa de concienciación.	Depende del modelo de referencia adoptado y de la calidad del criterio del evaluador.
Indicadores y KPI	Cuantitativo	Series comparables en el tiempo sobre desempeño en seguridad.	Puede incentivar el subreporte si se emplea con fines punitivos.

Nota. Elaboración propia a partir de las técnicas expuestas en las sesiones de la asignatura, de las fuentes de información previstas en ISO 19011:2018 y de los instrumentos incluidos en el Kit de Concienciación (INCIBE y METARED, s. f.).

La técnica más potente para este propósito específico es el simulacro de ataque dirigido, porque es la única que observa la conducta del usuario sin que este sepa que está siendo evaluado, evitando así el sesgo de deseabilidad que afecta a entrevistas y encuestas. El Kit de Concienciación proporciona precisamente esa instrumentación: campañas de phishing desplegadas con Gophish, ficheros maliciosos distribuidos mediante memorias USB y enlaces maliciosos remitidos por correo, con una herramienta de seguimiento que registra qué equipos ejecutaron el archivo (INCIBE y METARED, s. f.). Su aplicación en dos momentos, antes y después del proceso formativo, permite obtener una medida de variación y no solo una fotografía estática.

Ahora bien, un auditor no debería sustentar sus conclusiones en una sola técnica. La triangulación entre la conducta observada (simulacro), la conducta declarada (entrevista) y el registro documental (evidencia) permite formular hallazgos sólidos. Un caso frecuente lo ilustra: si la organización acredita documentalmente el cien por ciento de asistencia a la formación y, sin embargo, el simulacro posterior arroja una tasa de clic elevada, la conclusión pertinente no es que el personal sea negligente, sino que el control existe, pero es ineficaz, lo que orienta la recomendación hacia el rediseño del programa formativo y no hacia la sanción individual.

La tabla 4 propone un conjunto de indicadores susceptibles de ser verificados por el auditor, formulados de manera que puedan compararse entre periodos.

Tabla 4

Indicadores propuestos para la verificación auditora del factor humano

Indicador	Qué evidencia	Fuente de verificación
Cobertura formativa por rol	Alcance real del programa, desagregado por función y no solo agregado.	Registros de asistencia contrastados con la nómina y el organigrama.
Tasa de clic en simulacro de phishing	Conducta efectiva ante un estímulo controlado.	Informe de campaña de la herramienta de simulación.

Indicador	Qué evidencia	Fuente de verificación
Variación de la tasa de clic entre medición inicial y final	Eficacia atribuible al programa formativo.	Comparación de campañas pretest y posttest.
Tasa de reporte de correos sospechosos	Cultura de seguridad activa: el usuario no solo evita el clic, sino que alerta.	Registros del canal de reporte de incidentes.
Tiempo medio de reporte de incidentes	Capacidad de reacción del usuario, que condiciona la ventana de exposición.	Sistema de gestión de incidentes.
Resultados de tests de evaluación por unidad temática	Asimilación de contenidos, no solo exposición a ellos.	Tests incluidos en el material formativo.

Nota. Elaboración propia. Los indicadores se formulan para permitir comparación interanual, conforme al criterio de análisis cuantitativo expuesto en clase.

5.3 Límites, precauciones metodológicas y consideraciones legales

La evaluación del factor humano presenta restricciones que un auditor competente debe reconocer explícitamente en su informe.

- Reactividad y sesgo de deseabilidad. La observación directa altera la conducta observada, y las entrevistas tienden a recoger la respuesta que el entrevistado considera esperable. Ninguna de las dos técnicas mide, por sí sola, comportamiento habitual.
- Muestreo. Conforme a ISO 19011:2018, la auditoría se realiza en un tiempo delimitado y con recursos finitos, por lo que se basa en muestras; la confianza depositada en las conclusiones depende de la representatividad de esa muestra, extremo que debe quedar documentado.
- Encuadre ético y legal de los simulacros. El propio manual del kit recomienda capturar la contraseña solo de forma parcial para no afectar la privacidad del usuario y advierte que no se identificarán datos personales de los participantes. Un simulacro debe contar con autorización formal de la dirección, tratar los resultados de manera agregada y no individualizada, y respetar la normativa de protección de datos personales; en Colombia, la Ley 1581 de 2012.
- Finalidad formativa y no sancionatoria. Si el resultado del simulacro se emplea para sancionar, el efecto previsible es el subreporte, que degrada precisamente el indicador que se pretendía mejorar. El enfoque de la auditoría, según se subrayó en clase, debe ser constructivo e identificar oportunidades de mejora.
- Independencia y objetividad. El auditor no puede flexibilizar sus criterios por consideraciones de relación con la organización auditada; en clase se insistió en que la complacencia del auditor interno se traduce en hallazgos de la auditoría externa y compromete su propia posición profesional.

6. Propuesta de aplicación: el Kit de Concienciación como control auditable

Como cierre aplicado, la tabla 5 propone una lectura del Kit de Concienciación no como material didáctico aislado, sino como control interno documentado, mapeado sobre el ciclo PHVA y con la evidencia que quedaría disponible para el auditor en cada fase. Esta lectura permite responder simultáneamente a las tres preguntas del enunciado: incorpora al usuario como pieza del sistema, previene las consecuencias descritas y genera la evidencia verificable que la auditoría requiere.

Tabla 5

Mapeo del Kit de Concienciación sobre el ciclo PHVA y evidencia auditable resultante

Fase PHVA	Actividad del kit	Duración orientativa	Evidencia disponible para el auditor
Planear	Definición del alcance, designación del responsable y autorización de la dirección.	Previa al despliegue.	Acta de aprobación, alcance documentado, designación formal de responsable.
Verificar (línea base)	Ataques dirigidos iniciales: phishing con Gophish, memorias USB y enlace malicioso.	Aproximadamente un mes, en campañas de cinco días laborables con intervalos.	Informes de campaña con número de usuarios alcanzados; registro de equipos afectados.
Hacer	Distribución de pósteres y trípticos; despliegue de los nueve recursos formativos sobre seis temáticas.	Nueve meses, a razón de un recurso mensual.	Material distribuido, listas de asistencia, tests de evaluación calificados por unidad.
Verificar (medición final)	Recordatorio de ataques dirigidos con vectores de mayor dificultad de detección.	Seis semanas.	Informes comparables con la línea base; variación de la tasa de caída.
Actuar	Encuesta de satisfacción y ajuste del programa según resultados.	Un día laborable.	Resultados de la encuesta, plan de acción y oportunidades de mejora identificadas.

Nota. Elaboración propia a partir de la planificación descrita en el manual de implantación del kit, cuya duración total se estima en aproximadamente once meses y medio (INCIBE y METARED, s. f.). Los tiempos son orientativos y deben adaptarse al contexto de cada organización.

Conviene señalar una observación crítica sobre el instrumento. La versión analizada del manual data de un contexto anterior a la generalización de la autenticación multifactor, del teletrabajo masivo y de los fraudes asistidos por inteligencia artificial, incluida la suplantación de voz e imagen. Sus nueve unidades temáticas cubren información, correo electrónico, contraseñas, puesto de trabajo, dispositivos móviles y redes sociales, pero no abordan explícitamente estos vectores emergentes. Una organización que lo adopte debería complementarlo, y un auditor que evalúe el programa haría bien en verificar que los contenidos se mantienen actualizados, tal como exige el control A.6.3 de ISO/IEC 27001:2022 al requerir formación adecuada y actualizada.

8. Conclusiones

El recorrido realizado permite formular cuatro conclusiones.

Primera. Un SGSI no puede cumplir sus expectativas limitándose a imponer un marco tecnológico y normativo, y la razón principal no es de eficacia sino de conformidad: ISO/IEC 27001:2022 incorpora la toma de conciencia como requisito exigible en su cláusula 7.3 y como control específico en el A.6.3 de su Anexo A. Una organización que omitiera este componente estaría incumpliendo la norma que declara implementar.

Segunda. Las consecuencias de la falta de comprensión de las medidas de seguridad se despliegan en cuatro niveles: incidentes operativos, hallazgos de auditoría, costos económicos y legales, y una degradación sistémica de la capacidad del propio SGSI para medirse y mejorar. Este último nivel es el menos visible y probablemente el más costoso, porque puede presentarse acompañado de indicadores aparentemente favorables.

Tercera. El auditor debe evaluar la proximidad entre las dinámicas reales de uso y las políticas declaradas, porque la brecha que la auditoría busca identificar solo emerge del contraste entre ambas fuentes. Metodológicamente, ello exige triangular observación, entrevista, revisión documental e indicadores cuantitativos, reconociendo de

forma explícita las limitaciones de cada técnica y encuadrando los simulacros dentro de la normativa de protección de datos y con una finalidad formativa, no sancionatoria.

Cuarta. El Kit de Concienciación de INCIBE resulta valioso no solo como material didáctico, sino como instrumento que genera evidencia auditable, en la medida en que su diseño incorpora medición inicial, intervención formativa y medición final. Su adopción, no obstante, requiere actualización de contenidos frente a vectores de ataque que no estaban consolidados cuando el material fue elaborado.

En síntesis, el usuario no es el eslabón más débil de la cadena de seguridad por una condición inherente, sino por una decisión organizacional: la de haber invertido en tecnología sin invertir en comprensión. Reconocer al usuario como pieza fundamental del despliegue de controles internos supone, en consecuencia, tratar la concienciación con el mismo rigor de planificación, medición y verificación que se aplica a cualquier otro control del sistema.

9. Bibliografía

Las fuentes relacionadas a continuación sustentan los principales conceptos, argumentos y criterios desarrollados a lo largo de esta actividad. Se incluyen referencias normativas y técnicas relacionadas con la seguridad de la información y la auditoría de sistemas, así como el material de concienciación proporcionado por INCIBE y METARED. Asimismo, se incorpora la normativa colombiana aplicable a la protección de datos personales y se aclara el tratamiento de las comunicaciones personales utilizadas como fuente durante las sesiones de la asignatura.

- Congreso de la República de Colombia. (2012). Ley 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales. Diario Oficial No. 48.587.
- Instituto Nacional de Ciberseguridad. (s. f.). Kit de concienciación. Protege tu empresa. <https://www.incibe.es/protege-tu-empresa/kit-concienciacion>
- Instituto Nacional de Ciberseguridad y METARED. (s. f.). Kit de concienciación: Manual de implantación. <https://www.metared.org>
- Organización Internacional de Normalización. (2018). ISO 19011:2018. Directrices para la auditoría de los sistemas de gestión (3.ª ed.). ISO.
- Organización Internacional de Normalización y Comisión Electrotécnica Internacional. (2022). ISO/IEC 27001:2022. Seguridad de la información, ciberseguridad y protección de la privacidad. Sistemas de gestión de la seguridad de la información. Requisitos. ISO.
- Organización Internacional de Normalización y Comisión Electrotécnica Internacional. (2022). ISO/IEC 27002:2022. Seguridad de la información, ciberseguridad y protección de la privacidad. Controles de seguridad de la información. ISO.

Nota. Las referencias a W. Castaño Galvis corresponden a comunicaciones personales derivadas de las sesiones de la asignatura desarrolladas en agosto de 2026. Conforme a la norma APA (7.ª edición), las comunicaciones personales se citan únicamente en el texto y no se incluyen en la lista de referencias, al no constituir material recuperable por el lector.

10. AGRADECIMIENTO

Quiero expresar mi agradecimiento al docente Ing. y Dr. Wilson Castaño Galvis por compartir, con claridad y mediante ejemplos aplicados a situaciones reales, los fundamentos relacionados con los sistemas de gestión de seguridad de la información, los controles internos, la concienciación de los usuarios y el proceso de auditoría de los sistemas de información. Sus explicaciones y aportes durante las sesiones de la asignatura permitieron comprender la importancia del factor humano como elemento fundamental para la adecuada implementación y efectividad de los controles de seguridad.

Agradezco también a la universidad por disponer los espacios y recursos necesarios para el desarrollo de este módulo, así como a mis compañeros de curso por los aportes y discusiones que contribuyeron a enriquecer la comprensión de los conceptos abordados durante la asignatura. Este trabajo es el resultado de aplicar los conocimientos adquiridos al análisis del papel que desempeñan los usuarios en el despliegue de controles internos, considerando la concienciación como un componente esencial de un SGSI y la auditoría como mecanismo para verificar la efectividad de dichos controles.

¡Muchas gracias, respetado profesor, por el acompañamiento, la orientación y los conocimientos compartidos durante el desarrollo de esta actividad académica!

Respetuosamente,

Alejandro De Mendoza